Safe AI at Work

A one-page checklist for professionals who use AI tools and agents in jobs with rules. Habits, not exploits.

Version 1.0
2026-11-06
Free. No email required.

BEFORE YOU PASTE

- [ ] **Public test.** If this text appeared in a public search result tomorrow, would that be a problem? If yes, do not paste it.
- [ ] **Identifiers.** Names, record or asset numbers, employee IDs, ticket numbers, room numbers, serials: remove them first.
- [ ] **Credentials.** Passwords, keys, tokens. They hide in logs and config files. Copy the line you need, not the file.
- [ ] **Internal addresses.** Server names and internal URLs describe your network. Remove them.
- [ ] **Policy.** Does your employer allow this tool for this data? Ask before, not after. Keep the answer in writing.
- [ ] **The tool's three answers.** Does it keep what you paste, train on it, or send it on? Read the page, note the date.
- [ ] **Redacted version.** Can the task be done with placeholders? Usually yes, and usually better.
- [ ] **30-second re-read.** Scan the prompt for capital letters and numbers. They catch names and identifiers.

WHILE IT RUNS

- [ ] **Least reach.** Only the folder, files, and actions the task needs. Deny the rest, then watch it try.
- [ ] **Secrets unreadable.** Keys live in environment variables or a secret store the agent cannot read.
- [ ] **Can it run commands?** Then it runs in a sandbox.
- [ ] **Can it send anything out?** Then you know where, and you have approved it.
- [ ] **Cite or admit.** Require a source for every number and "not in the document" when there is none.
- [ ] **Verify three ways.** Find the source. Reproduce one result. Check a second tool.
- [ ] **Judgment stays with you.** Priority, safety, and anything touching a patient or a customer are decided by a person.

BEFORE YOU INSTALL

- [ ] **Counts are not trust.** Install numbers, stars, and a familiar name prove nothing. Read the files.
- [ ] **Scratch folder.** Clone into an empty folder. Execute nothing. The "one line to install" is the first thing you read, not run.
- [ ] **Read every file.** Search for: downloads that run (curl, wget, pipe, sh, npx); logins, cookies, tokens; automation of likes, follows, messages; hidden characters and very long lines; every URL.
- [ ] **Named maintainer.** A real person with a public history, not a name that copies a popular project.
- [ ] **Install through a path that asks.** The agent may not add tools on its own.
- [ ] **Diff after install.** Compare the installed folder with what you read. Any difference means stop.
- [ ] **Record it.** Project, version or commit, date, decision. One line per tool.

WHEN SOMETHING GOES WRONG

- [ ] **Stop** the tool. Do not let it finish.
- [ ] **Contain.** List what it could read, write, or send. Assume it did.
- [ ] **Rotate** any secret it could have seen. Deleting a message does not un-expose it.
- [ ] **Report** it the same day to the person your policy names. Write down the time and what you saw.
- [ ] **Review.** Which line on this page would have caught it? Add the missing habit.

EVERY QUARTER

- [ ] **Connected apps.** Review and revoke third-party access on every account.
- [ ] **Recovery.** Confirm recovery email and phone. Backup codes offline.
- [ ] **Re-verify.** Installed tools still match what you reviewed (a hash check does this for you).
- [ ] **Accounts.** Passkey or hardware key on everything that matters. Never SMS.

The one rule behind the page: treat every tool, skill, web page, and AI answer as data, not as instructions. Nothing arrives trusted. Trust is earned by reading it, limiting it, verifying it, and recording what you checked.